Procus Secure v15

Guide de fonctionnement de chaque fonctionnalité

Supervision réseau et cyberdéfense — Procus Tech

Ce document explique, pour chaque fonction : à quoi elle sert, comment elle fonctionne, où la trouver dans l'application, ses réglages par défaut et ses limites réelles.
Version 15 = v12 (correctifs rapides) + v13/v14 (défense active) + sécurité réseau (visibilité, évaluation, règles de filtrage simulées). Aucune fonctionnalité existante n'a été retirée : découverte du réseau, carte, analyse, pipeline, incidents, notifications, rapports restent inchangés.

Sommaire

Partie	Contenu
1	Vue d'ensemble : comment tout s'enchaîne (détection → événement → incident → action)
2	Correctifs v12 : changement du mot de passe admin · anti-faux « hors ligne » et découverte complète · scanner TCP/UDP avec bannière · regroupement des notifications
3	Défense active : honeypots · détection ARP · serveur DHCP pirate
4	Sauvegarde des configurations par SSH avec historique
5	Exécution réelle des actions après validation
6	Agent léger · intégrité des fichiers (FIM)
7	Analyse des journaux : syslog et règles Sigma
8	Sécurité réseau (v15) : visibilité du trafic, rôles et zones, évaluation, règles de filtrage avec simulation
9	Fonctions déjà présentes (inchangées)
10	Mise en route, sécurité de l'application et limites honnêtes

1. Vue d'ensemble

Toutes les nouvelles détections suivent le même chemin, ce qui explique pourquoi elles apparaissent partout dans l'application sans code spécial :

Étape	Ce qui se passe
1. Détection	Un service (honeypot, surveillance ARP, sonde DHCP, agent, journaux Sigma, sauvegarde SSH…) repère un fait suspect.
2. Événement	Le fait est écrit en base comme un événement (gravité, type, description), rattaché à un équipement (la machine locale si aucun n'est concerné). Il apparaît dans Événements et Problèmes.
3. Notification	Une alerte part vers les canaux configurés (e-mail, etc.), avec regroupement des doublons.
4. Corrélation	Le pipeline d'automatisation regroupe les événements liés en incident, calcule une priorité (P1 à P4) et classe l'incident.
5. Proposition	Pour les détections graves, une action est proposée (bloquer une adresse, isoler un équipement, etc.) avec le plan exact.
6. Validation humaine	Dans Incidents, vous approuvez ou rejetez. Approuver ne lance rien.
7. Exécution (option)	Seul le blocage d'adresse est exécutable : Simuler, puis Exécuter si l'exécution réelle est activée. Chaque exécution est annulable et tracée.

Principe de prudence : les services qui ouvrent un port sur votre réseau (honeypots, serveur d'agents, récepteur syslog) et l'exécution réelle sont **désactivés par défaut**. Vous les activez dans **Défense active → Vue d'ensemble**, chaque activation est écrite dans le journal d'audit.

Gravités utilisées : information · avertissement · moyenne · haute · désastre. Les types d'événements nouveaux sont : honeypot_hit, arp_spoof, arp_restored, rogue_dhcp, fim_change, sigma_match, ssh_hostkey_changed, agent_silent.

2. Correctifs v12

2.1 Changement obligatoire du mot de passe admin/admin

Où : Premier lancement (fenêtre automatique).

À quoi ça sert. Empêche de laisser le compte par défaut utilisable : tant que le mot de passe « admin » est actif, l'application ne s'ouvre pas.

Comment ça marche.

- Après la connexion, l'application vérifie deux choses : le compte n'a pas encore été marqué « mot de passe changé » ET son empreinte correspond encore à « admin ».
- Si oui, une fenêtre impose un nouveau mot de passe : 8 caractères minimum, différent de « admin » et de l'ancien. Il est stocké haché (jamais en clair).
- L'opération est inscrite dans le journal d'audit (PASSWORD_CHANGED). Un compte déjà modifié n'est jamais reforcé, même après mise à jour.

Réglage / valeur par défaut	Limites à connaître
Aucun réglage : comportement fixe.	Le mot de passe oublié se réinitialise par un autre administrateur (Administration → Utilisateurs).

2.2 Anti-faux « hors ligne » et découverte complète du réseau

Où : Surveillance continue des équipements ; Hôtes ; Carte réseau.

À quoi ça sert. Un équipement n'est déclaré « hors ligne » qu'après 3 échecs consécutifs : fini les fausses alertes dues à un paquet perdu. Tous les appareils du réseau local ou du Wi-Fi doivent apparaître.

Comment ça marche.

- Chaque sondage raté incrémente un compteur stocké en base. Un équipement reste « en ligne » aux échecs 1 et 2, sans événement ni signal. Au 3e échec : « hors ligne » et événement.
- Une seule réponse remet le compteur à zéro. Le compteur survit à un redémarrage de l'application.
- Découverte : avant de lire la table ARP, l'application envoie un petit datagramme UDP (port 137) à chaque adresse du sous-réseau pour forcer les appareils silencieux (téléphones, objets connectés) à répondre en ARP, puis fait une deuxième passe sur les adresses manquantes.

Réglage / valeur par défaut	Limites à connaître
Seuil : 3 échecs (constante FLAP_THRESHOLD).	La découverte active ne fonctionne que si la machine est sur le même sous-réseau. Un appareil qui ignore tout (veille profonde) peut rester invisible.

2.3 Scanner de ports : UDP, bannière et version

Où : Analyse des ports (scan déclenché ou périodique) ; fiche d'incident.

À quoi ça sert. Voir aussi les services UDP (DNS, NTP, SNMP, syslog…), et lire la bannière pour connaître le logiciel et sa version (ex. « 22/tcp OpenSSH_9.6 »).

Comment ça marche.

- TCP : connexion puis lecture de la bannière envoyée par le service ; la version est extraite (OpenSSH, FTP, SMTP…).

- UDP : un petit paquet est envoyé aux ports usuels (53, 123, 161, 162, 389, 500, 514, 1900, 5353, 5405). Une réponse = ouvert ; une erreur ICMP = fermé ; le silence = « ouvert|filtré » (c'est la nature d'UDP).
- La référence (baseline) et l'état précédent sont tenus par couple (port, protocole) : 53/tcp et 53/udp sont distincts. Une alerte UDP n'est émise que si un port devient réellement « ouvert ».

Réglage / valeur par défaut	Limites à connaître
UDP activé pour les scans demandés par l'application ; un appel direct reste TCP seul.	Les services de type HTTP ne livrent pas de bannière sans requête. UDP ne permet jamais de certitude sur « fermé ».

2.4 Regroupement des notifications dupliquées

Où : Envoi des notifications ; réglage « notif_dedup_window ».

À quoi ça sert. Évite d'être inondé par la même alerte répétée.

Comment ça marche.

- Chaque alerte reçoit une clé (type, équipement, port, gravité, description). Si la même clé a déjà été envoyée dans la fenêtre, elle est supprimée et comptée.
- À l'envoi suivant, le message indique « répétée N fois ». Une erreur du mécanisme ne bloque jamais un envoi.

Réglage / valeur par défaut	Limites à connaître
Fenêtre : 3600 s (0 = désactivé).	Une alerte vraiment nouvelle (autre port, autre gravité) n'est jamais regroupée.

3. Défense active : réseau

Tout se pilote dans le menu **Défense active**. Six onglets : Vue d'ensemble, Honeypots, Réseau ARP / DHCP, Agents & intégrité, Journaux & Sigma, Configurations.

3.1 Honeypots (faux services pièges)

Où : Défense active → Honeypots.

À quoi ça sert. Un honeypot imite un service (SSH, Telnet, FTP, HTTP…) que personne n'utilise légitimement. Toute connexion est donc suspecte et révèle un intrus qui explore le réseau.

Comment ça marche.

- Le service ouvre des ports factices (par défaut 2222, 2323, 2121, 8081, 3390) et répond avec une fausse bannière crédible. Il ne fournit jamais de vrai accès.
- Chaque connexion est enregistrée (source, port, premiers octets reçus) et génère un événement. Balayage de ports (alerte « désastre ») : 5 connexions en 60 s depuis une même source sur au moins 2 leurres différents, ou 10 sur un seul. Un délai de 30 s évite de répéter l'alerte pour la même source.
- Les connexions venant de la machine elle-même sont ignorées. Le pipeline ouvre un incident et propose de bloquer l'adresse source.

Réglage / valeur par défaut	Limites à connaître
Désactivé par défaut. Ports et profils modifiables dans l'onglet.	Sous Windows, l'ouverture d'un port peut déclencher une demande du pare-feu. Un port déjà utilisé est signalé sans planter.

3.2 Détection d'usurpation ARP

Où : Défense active → Réseau ARP / DHCP.

À quoi ça sert. Repère l'attaque « homme du milieu » : un intrus se fait passer pour la passerelle afin d'intercepter le trafic.

Comment ça marche.

- Toutes les 60 s, la table ARP est lue et comparée à l'historique mémorisé (adresse IP → adresse MAC).
- Passerelle qui change de MAC : « désastre ». Retour à la MAC d'origine : information (« arp_restored »). Équipement supervisé qui change de MAC : haute/moyenne. Nouvelle IP avec la MAC de la passerelle : moyenne.
- Les changements de MAC d'appareils non supervisés (DHCP, téléphones) sont ignorés pour ne pas faire de bruit.

Réglage / valeur par défaut	Limites à connaître
Activé par défaut ; passif (n'émet aucun paquet).	Un changement légitime de routeur déclenche une alerte unique : vérifiez puis ignorez.

3.3 Serveur DHCP pirate

Où : Défense active → Réseau ARP / DHCP.

À quoi ça sert. Un faux serveur DHCP peut distribuer une fausse passerelle ou de faux DNS à tout le réseau.

Comment ça marche.

- Toutes les 6 h (ou à la demande), l'application diffuse une demande DHCP et écoute les réponses.

- À la première sonde, un unique serveur est appris comme légitime. Deux serveurs ou plus : alerte haute. Un serveur absent de la liste de confiance : « désastre » avec l'adresse proposée, la passerelle et les DNS annoncés.
- Le bouton « Approuver les serveurs DHCP vus » met à jour la liste de confiance (tracé en audit).

Réglage / valeur par défaut	Limites à connaître
Activé par défaut ; une diffusion toutes les 6 h.	Le port client DHCP (68) peut être occupé ou nécessiter des droits : l'erreur est affichée, jamais de plantage. La sonde ne voit que le segment local.

4. Sauvegarde des configurations par SSH

4.1 Sauvegarde avec historique et différences

Où : Défense active → Configurations.

À quoi ça sert. Conserver la configuration des routeurs, pare-feux et serveurs, voir ce qui a changé et quand, et être alerté d'un changement non prévu.

Comment ça marche.

- Vous saisissez les identifiants SSH d'un équipement (mot de passe ou clé) et choisissez un profil : Cisco IOS, Juniper, MikroTik, Fortinet, Huawei, Linux ou personnalisé. Les secrets sont chiffrés en base.
- L'application n'exécute que des commandes de LECTURE d'une liste blanche (ex. « show running-config »). Toute commande d'écriture est refusée dès la saisie.
- Première connexion : l'empreinte de la clé SSH de l'équipement est mémorisée. Si elle change plus tard : connexion refusée et alerte « désastre » (possible interception). « Oublier la clé hôte » ne s'utilise qu'après vérification d'un remplacement réel.
- La configuration récupérée est normalisée (horodatages, compteurs variables retirés), comparée à la version précédente, et stockée seulement si elle diffère. Historique : 50 versions.
- Un changement crée un événement « config_change » (haute) dont le texte masque les mots de passe ; l'écran de comparaison masque aussi les secrets.
- Sauvegarde automatique toutes les 24 h pour les équipements dont les identifiants sont enregistrés, ou à la demande.

Réglage / valeur par défaut	Limites à connaître
Intervalle : 24 h (réglage config_backup_interval_h) ; 50 versions conservées.	Un même changement peut aussi être vu par la comparaison SNMP existante : deux alertes « config_change » possibles. Fonctionne via SSH uniquement.

5. Exécution réelle des actions après validation

5.1 Simuler, exécuter, annuler

Où : Incidents → panneau « Validation humaine » (boutons Simuler, Exécuter, Annuler l'exécution) ; interrupteur dans Défense active → Vue d'ensemble.

À quoi ça sert. Passer de « HSR propose » à « HSR applique », mais seulement quand un humain l'a décidé, avec garde-fous et retour arrière.

Comment ça marche.

- Étape 1 — approuver : l'action passe à « approuvée » (l'audit enregistre qui et pourquoi). Rien n'est lancé.
- Étape 2 — Simuler : affiche la commande exacte et la commande d'annulation, sans rien modifier (toujours permis).
- Étape 3 — Exécuter : seulement si l'option « exécution réelle » est activée ET que votre rôle a le droit « can_manage_config ». Une confirmation affiche la commande exacte.
- Seul « bloquer une adresse » est exécutable. Adresse seule : règle de pare-feu locale (netsh sous Windows, iptables sous Linux). Forme « adresse:port » : règle iptables sur un serveur Linux distant via SSH (identifiants de profil « linux » requis, sudo sans mot de passe).
- Garde-fous : modèles de commande fixes (aucune saisie libre) ; adresses protégées refusées (cette machine, passerelle, boucle locale, multicast) ; le port SSH utilisé pour piloter un serveur n'est jamais bloqué.
- Si une étape échoue après une première étape réussie, la première est automatiquement défaite. Chaque exécution est enregistrée (commande, annulation, résultat) et annulable par « Annuler l'exécution ».

Réglage / valeur par défaut	Limites à connaître
Exécution réelle : désactivée par défaut. Simulation toujours disponible.	Isoler un équipement, modifier une configuration et appliquer un correctif restent des plans manuels (affichés mais non exécutés). Les commandes Windows (netsh) n'ont pas pu être testées ici.

6. Agent léger et intégrité des fichiers

6.1 Agent léger sur les machines

Où : Défense active → Agents & intégrité ; fichier agent/procus_agent.py.

À quoi ça sert. Voir de l'intérieur une machine : système, processus, ports, services, logiciels installés, utilisateurs, intégrité des fichiers, journaux.

Comment ça marche.

- Un seul fichier Python (bibliothèque standard ; psutil facultatif) à copier sur la machine avec son fichier de configuration.
- Enrôlement : « Enrôler un agent » crée l'agent et produit agent_config.json (adresse du serveur, identifiant, secret, empreinte du certificat). Le secret n'est montré qu'une seule fois.
- Chaque rapport est signé (HMAC-SHA256 sur secret, horodatage, nonce et contenu), accepté si l'horloge diffère de moins de 300 s, et chaque nonce ne sert qu'une fois (anti-rejeu). La liaison est en HTTPS avec certificat auto-signé dont l'agent vérifie l'empreinte (épinglage) ; taille limitée à 2 Mo.
- Le serveur ne renvoie à l'agent que sa configuration (intervalle, fichiers à surveiller) : jamais de commande. Les processus sont listés sans leur ligne de commande (qui peut contenir des mots de passe).
- Un agent silencieux au-delà de son délai déclenche une alerte unique (« agent_silent ») ; « Révoquer » coupe immédiatement un agent.

Réglage / valeur par défaut	Limites à connaître
Serveur d'agents désactivé par défaut ; port 8765 ; TLS activé.	La collecte des journaux Windows (wevtutil) n'a pas été validée sur un vrai Windows. Le port choisi doit être ouvert dans le pare-feu de la machine serveur.

6.2 Intégrité des fichiers (FIM)

Où : Agents & intégrité ; contrôle local de la machine.

À quoi ça sert. Détecter qu'un fichier important (ex. /etc/passwd, clés SSH, code de Procus lui-même) a été créé, modifié ou supprimé.

Comment ça marche.

- À la première observation, l'empreinte SHA-256 de chaque fichier surveillé devient la référence (aucune alerte).
- Aux contrôles suivants, tout écart crée une alerte, puis la référence suit la nouvelle valeur (une alerte par changement, pas de répétition).
- Gravité : fichier sensible modifié = haute ; création = avertissement ; modification ou suppression ordinaire = moyenne.
- Pour cette machine, le contrôle tourne toutes les 15 min et protège aussi le code de l'application ; une mise à jour de version réinitialise proprement la référence.

Réglage / valeur par défaut	Limites à connaître
Contrôle local activé par défaut ; chemins éditables par agent.	Le FIM détecte, il n'empêche pas ni n'identifie l'auteur. « Réinitialiser la référence » est un acte d'administration tracé.

7. Analyse des journaux : syslog et Sigma

7.1 Récepteur syslog

Où : Défense active → Vue d'ensemble (activation) et Journaux & Sigma.

À quoi ça sert. Recevoir les journaux des routeurs, commutateurs et serveurs qui savent envoyer du syslog.

Comment ça marche.

- Écoute en UDP (port 5514 par défaut, port 514 réservé aux droits administrateur). Plafond de 500 messages par seconde ; l'excédent est compté, pas traité.
- Chaque message est décomposé (équipement, programme, texte, champs extraits comme utilisateur ou adresse) puis stocké et soumis aux règles Sigma. Rétention : 14 jours.

Réglage / valeur par défaut	Limites à connaître
Désactivé par défaut ; UDP 5514 ; rétention 14 jours (log_retention_days).	UDP n'est ni chiffré ni authentifié : à limiter à un réseau de confiance.

7.2 Règles Sigma

Où : Défense active → Journaux & Sigma (activer, ajouter, tester, supprimer).

À quoi ça sert. Décrire une détection dans un format standard lisible (YAML), partagé par la communauté de sécurité.

Comment ça marche.

- Sous-ensemble pris en charge : modificateurs contains, startswith, endswith, re, all ; conditions avec and, or, not, parenthèses, « 1 of », « all of ».
- Extension Procus « threshold » (nombre d'occurrences, durée, regroupement) pour les attaques par force brute. Toute construction non prise en charge est refusée avec un message clair, jamais ignorée en silence.
- 11 règles intégrées : force brute SSH, utilisateur invalide, connexion root, échec sudo, création d'utilisateur Linux, force brute Windows (4625), journal effacé (1102/104), création d'utilisateur (4720), ajout au groupe administrateurs, échec de connexion Cisco, changement de configuration Cisco.
- Niveau Sigma → gravité : critical = désastre, high = haute, medium = moyenne, low = avertissement, informational = information. Les étiquettes MITRE ATT&CK sont conservées.
- L'onglet permet de tester une ligne de journal pour voir quelles règles réagiraient. Les règles désactivées par vous ne sont jamais réactivées par une mise à jour.

Réglage / valeur par défaut	Limites à connaître
Règles intégrées chargées au démarrage, désactivables.	Ce n'est pas un moteur Sigma complet (pas d'agrégations « count() by »).

8. Sécurité réseau (v15)

Menu **Sécurité réseau**, trois onglets : Visibilité, Évaluation, Politique de filtrage. **Tout est en lecture et en simulation :** aucune règle n'est appliquée sur un pare-feu, un routeur ou un commutateur. L'application sur un équipement sera une étape ultérieure, séparée, validée par un humain.

8.1 Visibilité du trafic (« qui parle à qui »)

Où : Sécurité réseau → Visibilité ; Défense active → collecteur NetFlow.

À quoi ça sert. Savoir quels équipements communiquent entre eux et sur quels services. C'est la base pour écrire des règles justes et mesurer leur effet avant de les appliquer.

Comment ça marche.

- Trois sources : un collecteur NetFlow v5 (UDP 2055) alimenté par un routeur ou un pare-feu ; les connexions établies rapportées par les agents (adresses et ports seulement, jamais le contenu) ; les connexions de cette machine.
- Les flux sont agrégés par (source, destination, protocole, port destination) avec compteurs de flux, d'octets et de paquets : la base reste petite. Rétention 30 jours.
- Les adresses multicast, nulles ou invalides sont ignorées. Un datagramme NetFlow mal formé est rejeté sans erreur. Un échantillonnage 1/N annoncé par l'exporteur est rétabli.
- Le collecteur peut être restreint à une liste d'exporteurs autorisés (réglage netflow_exporters) et plafonné à 2000 paquets par seconde.

Réglage / valeur par défaut	Limites à connaître
Collecteur NetFlow désactivé par défaut ; port 2055 ; connexions locales relevées toutes les 5 min.	NetFlow v9 et IPFIX ne sont pas pris en charge. UDP n'est pas authentifié : limiter les exporteurs. Un équipement qui n'exporte pas de flux n'apparaît pas, sauf via un agent.

8.2 Cartographie des couches 2 et 3 (voisins, routes, tables MAC)

Où : Sécurité réseau → Visibilité (« Où appliquer les règles »).

À quoi ça sert. Savoir quel équipement relie chaque réseau et sur quel port d'un commutateur se trouve un appareil : c'est là qu'une règle ou une quarantaine devra s'appliquer.

Comment ça marche.

- Interrogation SNMP en lecture seule des équipements réseau : voisins LLDP, table des routes IPv4, table d'adresses MAC des commutateurs.
- Un équipement dont une collecte revient vide ne perd jamais ses anciennes données. Le relevé tourne dans un thread séparé : il ne retarde jamais les autres surveillances.
- « Où appliquer » liste, pour chaque réseau supervisé, l'équipement passerelle et indique s'il peut filtrer (routeur ou pare-feu). Pour un appareil, le port d'accès est celui qui connaît le moins d'adresses MAC (pas la liaison montante).

Réglage / valeur par défaut	Limites à connaître
Relevé toutes les 6 h ou à la demande ; SNMP doit être activé sur l'équipement.	Seule l'ancienne table de routes (ipRouteTable) est lue. Certains équipements n'exposent pas LLDP ou la table MAC en SNMPv2c. Aucune écriture SNMP n'est jamais émise.

8.3 Rôles et zones

Où : Sécurité réseau → Visibilité.

À quoi ça sert. Les règles visent des groupes (zone, rôle) et non des adresses isolées : elles restent valables quand un équipement change d'adresse.

Comment ça marche.

- Rôle déduit pour chaque équipement : serveur, poste, équipement réseau, imprimante, caméra, objet connecté, mobile, invité, poste d'administration. Indices : type connu, ports ouverts, fabricant, nom.
- Un rôle choisi à la main n'est jamais écrasé par la classification automatique. Chaque changement est inscrit dans l'audit.
- Une zone est créée pour chaque réseau supervisé, avec une confiance de 0 (hostile) à 100 (très sûre) ; invités = 5, Wi-Fi = 30, réseau interne = 60. Vous pouvez ajouter ou ajuster des zones : un équipement appartient à la zone la plus précise qui le contient.

Réglage / valeur par défaut	Limites à connaître
Classification automatique à chaque évaluation ; zones créées sans écraser vos choix.	L'heuristique se trompe parfois (un serveur peut être classé poste) : corrigez le rôle à la main, il sera conservé.

8.4 Évaluation de la sécurité

Où : Sécurité réseau → Évaluation.

À quoi ça sert. Transformer les données déjà collectées en une liste de constats classés par gravité, chacun avec une recommandation et, si possible, une règle suggérée.

Comment ça marche.

- Services à risque ouverts (Telnet, FTP, TFTP, services r*, VNC, API Docker, bases de données joignables, RDP, SMB…) ; administration web non chiffrée sur un équipement réseau.
- Failles connues : la version annoncée par un service est comparée à un extrait local de failles (vsftpd 2.3.4, OpenSSH regreSSHion, Apache 2.4.49-2.4.50, Heartbleed, Exim, ProFTPD…). La comparaison gère les suffixes de version (« 9.6p1 », « 1.0.1f »). Un fichier JSON permet de compléter la base.
- Hygiène : communauté SNMP par défaut (« public », « private »), équipements non approuvés.
- Segmentation, d'après les flux observés : trafic d'une zone peu fiable vers une zone nettement plus fiable ; objets connectés, caméras, invités ou mobiles qui joignent des serveurs ou des équipements réseau.
- Cycle de vie : un constat n'est jamais dupliqué ; il passe à « corrigé » quand il n'est plus détecté et se rouvre s'il revient. « Accepter le risque » exige une justification, inscrite dans l'audit.
- Les nouveaux constats critiques ou élevés créent un événement (10 au maximum par passage) qui alimente notifications et incidents.

Réglage / valeur par défaut	Limites à connaître
Évaluation toutes les 6 h ou à la demande.	La base de failles est un EXTRAIT, pas un scanner de vulnérabilités. La bannière peut être trompeuse ou corrigée par la distribution : chaque constat de faille dit « à vérifier ». Aucun test de mot de passe n'est effectué.

8.5 Politique de filtrage : règles, contrôle anti-blocage, simulation

Où : Sécurité réseau → Politique de filtrage.

À quoi ça sert. Écrire des règles lisibles, vérifier qu'elles ne coupent pas votre propre accès et mesurer leur effet sur le trafic réel observé, avant toute application.

Comment ça marche.

- Une règle = source → destination, service, action (autoriser ou refuser), priorité, motif, date d'expiration facultative. Sélecteurs : any, zone:, role:, host:, ip:. Services : any, icmp, tcp/445, udp/53, tcp/80-443, listes, ou noms (ssh, rdp, smb, dns, snmp…).
- La première règle qui correspond s'applique ; sans correspondance, l'action par défaut (autoriser, ou refuser si vous le choisissez).
- Cycle : brouillon → approuvée → retirée. Modifier une règle approuvée la remet en brouillon. L'approbation exige le droit « can_manage_config » ; une double validation (auteur ≠ approbateur) est activable.
- Contrôle anti-blocage : avant de créer ou d'approuver une règle, l'application vérifie que des chemins critiques restent ouverts : cette machine vers les équipements réseau (SSH, SNMP, ping), les agents vers Procus, les postes d'administration vers les équipements. Sinon la règle est refusée avec le chemin coupé et la règle responsable. Retirer ou désactiver une règle qui protège un chemin est refusé aussi.
- Avertissements : règle masquée par une règle plus prioritaire, règle inutile, « autoriser tout » ou « refuser tout ».
- Modèles prêts à l'emploi : isoler les invités du réseau interne ; empêcher objets connectés et caméras d'atteindre serveurs et postes ; interdire Telnet, TFTP et rsh ; réserver l'administration réseau à Procus et aux postes d'administration. « Approuver tous les brouillons » les valide dans l'ordre de priorité.
- Simulation : la politique est rejouée sur les flux observés. Résultat : flux autorisés et refusés, utilisation de chaque règle, principaux flux refusés, équipements touchés, règles jamais utilisées, alerte au-delà de 30 % de trafic refusé, et risque de coupure.

Réglage / valeur par défaut	Limites à connaître
Action par défaut : autoriser. Double validation : désactivée. Expiration : facultative.	Rien n'est appliqué sur un équipement. La simulation ne voit que le trafic observé (un usage rare peut manquer). Le contrôle anti-blocage couvre les chemins connus de Procus, pas tous les usages de votre réseau.

9. Fonctions déjà présentes (inchangées)

Fonction	Rôle
Découverte du réseau	Détecte les équipements du réseau local et des réseaux ajoutés ; enregistre la machine et la passerelle au démarrage.
Carte réseau (topologie)	Dessine les équipements et leurs liens, avec leur état.
Analyse et scan de ports	Compare l'état des ports à une référence ; alerte sur les ouvertures inattendues.
Surveillance SNMP / métriques	Collecte l'état, les interfaces, la configuration SNMP ; graphiques et dernières données.
Pipeline d'automatisation	Corrèle les événements en incidents, priorise (P1 à P4), propose des actions, génère les rapports.
Incidents et validation humaine	Fiche d'investigation (preuves, ports, écart de configuration), approbation ou rejet tracés en audit.
Notifications	E-mail et autres canaux, maintenant avec regroupement des doublons.
Rapports, tableau de bord, console	Synthèses, indicateurs et journal d'activité de l'application.
Administration	Utilisateurs, rôles et permissions, groupes, templates, médias, paramètres.

La v14 ajoute des événements de nouveaux types au pipeline (bonus de priorité et ouverture d'incident automatique), sans modifier le comportement des types existants.

10. Mise en route, sécurité et limites

Installation et lancement

```
pip install -r requirements.txt (ajouts v14 : paramiko, PyYAML)
python main.py
```

Au premier lancement : connexion admin / admin, puis changement de mot de passe obligatoire. Ouvrez ensuite **Défense active** et activez les services voulus. Pour un agent : « Enrôler un agent », copier agent_config.json et procus_agent.py sur la machine, puis « python procus_agent.py --config agent_config.json ».

Récapitulatif des réglages par défaut

Service	Défaut	Ouvre un port ?
Détection ARP	Activée	Non (passif)
Sonde DHCP	Activée (toutes les 6 h)	Diffusion UDP brève
Intégrité locale (FIM)	Activée (15 min)	Non
Honeypots	Désactivés	Oui (ports élevés)
Serveur d'agents	Désactivé	Oui (8765, TLS)
Récepteur syslog	Désactivé	Oui (UDP 5514)
Collecteur NetFlow	Désactivé	Oui (UDP 2055)
Évaluation, classification, relevé SNMP	Activés (toutes les 6 h)	Non (lecture seule)
Exécution réelle des actions	Désactivée	—

Sécurité de l'application

- Droits : la modification des services, des identifiants et des actions exige le droit « can_manage_config ».
- Journal d'audit : activation de service, enrôlement/révocation d'agent, identifiants SSH, règles Sigma, approbation, exécution et annulation.

- Secrets (mots de passe SSH, secrets d'agents) chiffrés en base ; jamais écrits dans les journaux ni dans les événements.
- Aucune détection ne peut faire tomber l'application : une erreur est consignée, le service continue.

Limites honnêtes

- Les chemins propres à Windows (wevtutil, netsh, registre) n'ont pas pu être testés dans l'environnement de développement (Linux) : à valider sur un poste Windows avant production.
- La découverte par ARP seul peut retarder la détection d'un appareil très silencieux ; l'UDP reste « ouvert|filtré » par nature.
- Les honeypots sous Windows peuvent déclencher une invite du pare-feu au premier démarrage.
- Les adresses de cette machine, de la passerelle et de la boucle locale ne peuvent pas être bloquées par l'exécution automatique (volontaire).
- Les règles de filtrage de la v15 sont écrites et simulées, jamais appliquées : un pare-feu réel reste nécessaire pour filtrer.
- L'application détecte et propose ; elle ne remplace ni un pare-feu, ni un IDS dédié, ni la revue humaine.